

MAHINDRA & MAHINDRA LTD

Human Resources | People Excellence Division

BUSINESS REQUIREMENTS DOCUMENT

MESOP

Employee Stock Option Platform

A Unified Portal for ESOP Grant, Exercise & Administration

DOCUMENT INFORMATION	
Document Reference	MM-HR-MESOP-BRD-001
Version	1.0
Status	Final Draft
Prepared By	HR Technology Team
Reviewed By	HR Leadership
Date	March 30, 2026

CONFIDENTIAL

This document contains proprietary information of Mahindra & Mahindra Ltd. It is intended solely for authorised personnel and must not be disclosed externally.

Table of Contents

1.	Executive Summary	3
2.	Project Overview	3
3.	Business Objectives	4
4.	Scope of the Project	4
5.	Stakeholders	5
6.	Functional Requirements	5
6.1	Authentication & Authorization	5
6.2	Employee Module	6
6.3	HR Module	6
6.4	Trust Department Module	7
6.5	Dashboard & Analytics	7
6.6	Reports & Audit	8
7.	Non-Functional Requirements	8
8.	System Architecture	9
9.	Data Requirements	9
10.	Security Requirements	10
11.	Integrations	11
12.	Assumptions & Constraints	11
13.	Risks & Mitigation	12
14.	Glossary	12

1. Executive Summary

Mahindra & Mahindra Ltd. is implementing MESOP (Mahindra Employee Stock Option Platform), a comprehensive digital solution to manage the full lifecycle of employee stock options (ESOPs). The platform replaces manual, spreadsheet-driven processes with a secure, role-based web application accessible to Employees, HR Personnel, and Trust Department representatives.

MESOP centralises grant management, option exercise processing, separation case tracking, and demat operations into a single integrated portal. The platform provides real-time dashboards, audit trails, and reporting capabilities to support data-driven decision-making and compliance with statutory requirements.

2. Project Overview

2.1 Background

Mahindra & Mahindra currently manages ESOP operations through disparate processes involving manual data entry, email communication between HR and Trust departments, and siloed spreadsheets. This creates operational inefficiencies, data inconsistencies, and audit trail gaps. MESOP addresses these challenges by providing a unified digital platform.

2.2 Project Vision

To provide a seamless, secure, and transparent ESOP management experience for all stakeholders — from grant creation by HR to final transfer execution by the Trust department — while ensuring full auditability and regulatory compliance.

2.3 Technology Stack

Layer	Technology	Version	Purpose
Frontend	React	18.3.1	Single Page Application UI framework
Frontend	Vite	5.4.14	Build tool and development server
Frontend	React Router	6.30.3	Client-side SPA routing
Frontend	Axios	1.8.4	HTTP client for API communication
Backend	ASP.NET Core	8.0	REST API framework
Backend	Entity Framework Core	8.0	ORM / database access layer
Database	MySQL	8.0+	Relational data persistence
Auth	JWT Bearer Tokens	-	Stateless API authentication
Security	BCrypt.Net	4.0.3	Adaptive password hashing
Infra	Docker	Latest	Containerised backend deployment

3. Business Objectives

- Digitise end-to-end ESOP lifecycle management — from grant issuance through vesting to exercise and transfer.
- Eliminate manual data-entry errors and reduce processing time for stock option exercises.
- Give employees self-service access to their ESOP portfolio, vesting schedules, and exercise history.
- Enable HR to create, track, and manage grants and employee separation cases in one place.
- Empower the Trust department to manage share transfers and demat operations through a structured workflow.

- Ensure comprehensive, tamper-evident audit trails for all ESOP transactions to support regulatory compliance.
- Deliver real-time dashboards with role-specific KPIs and stock price trends for informed decision-making.
- Establish role-based access control to protect sensitive financial and personal data from unauthorised access.

4. Scope of the Project

4.1 In Scope

- Role-based authentication and session management (Employee, HR, Trust)
- Employee profile management: personal details, demat account, nominee information
- ESOP grant creation, tracking, and status management by HR
- Stock option exercise request submission and tracking by employees
- Employee separation case creation and management by HR
- Share transfer and demat operations management by Trust department
- Role-specific dashboards with KPI cards and stock price trend visualisation
- Paginated audit log reports and leave utilisation reports
- Containerised backend deployment (Docker)
- REST API with Swagger/OpenAPI documentation

4.2 Out of Scope

- Single Sign-On (SSO) / Active Directory / LDAP integration
- Real-time stock price feed from BSE/NSE market data providers
- Email or SMS notifications for exercise approvals or status changes
- Mobile application (iOS / Android)
- Multi-company or multi-tenant support
- Automated tax calculation for option exercises
- ERP / SAP integration for payroll deduction
- Document upload and storage for KYC / demat account documents

5. Stakeholders

Stakeholder	Role	Interest / Responsibility
Employees	End Users	View ESOP portfolio, manage profile, submit exercise requests
HR Personnel	Administrators	Create grants, manage separations, monitor ESOP data
Trust Department	Operations	Process share transfers, manage demat instructions
HR Leadership	Project Sponsors	Define requirements, approve policies and reports
IT / DevSecOps	Implementors	Deploy, maintain, and secure the platform infrastructure
Finance / Legal	Compliance	Ensure regulatory compliance for all ESOP transactions
Employees (as Data Subjects)	Data Subjects	Rights over personal/financial data under India DPDP Act 2023

6. Functional Requirements

6.1 Authentication & Authorization

The system shall provide secure, role-based access control for all users.

Req. ID	Requirement	Priority
FR-AUTH-001	System shall authenticate users via email and password credentials	High
FR-AUTH-002	System shall issue JWT tokens on successful login with an 8-hour expiry	High
FR-AUTH-003	System shall enforce three distinct roles: Employee, HR, and Trust	High
FR-AUTH-004	Passwords shall be stored using BCrypt hashing — never in plaintext	High
FR-AUTH-005	Frontend shall persist session in localStorage to survive browser reloads	Medium
FR-AUTH-006	Protected API endpoints shall return HTTP 401/403 on role violations	High
FR-AUTH-007	Users shall be able to log out, which clears the token from the client	High

6.2 Employee Module

Authenticated employees shall have self-service access to their profile and stock option exercise features.

Req. ID	Requirement	Priority
FR-EMP-001	Employee shall view their profile: name, department, demat account, nominee	High
FR-EMP-002	Employee shall update their demat account number and nominee name	High
FR-EMP-003	Employee shall view all their grants with vesting status and exercise price	High
FR-EMP-004	Employee shall submit an exercise request: grant ID, quantity, payment mode	High
FR-EMP-005	Exercise requests shall be persisted with timestamp and status "Submitted"	High
FR-EMP-006	Employee shall view exercise request history via the audit log report	Medium
FR-EMP-007	HR role shall also have read access to employee profiles for admin purposes	Medium

6.3 HR Module

HR personnel shall manage the full grant lifecycle and employee separation cases.

Req. ID	Requirement	Priority
FR-HR-001	HR shall create grants: employee code, grant date, option count, exercise price	High
FR-HR-002	HR shall set grant status during creation (Active, On Hold, Expired, etc.)	High
FR-HR-003	HR shall view all grants ordered by creation date, most recent first	High

FR-HR-004	HR shall create separation cases: employee code, initiation type, effective date, notes	High
FR-HR-005	HR shall view all separation cases with their current processing status	High
FR-HR-006	HR shall access employee profiles for data verification	Medium
FR-HR-007	HR dashboard KPIs: Open Grants, On Hold Cases, Transfer Cases count	Medium

6.4 Trust Department Module

The Trust department shall manage share transfer cases and demat instruction operations.

Req. ID	Requirement	Priority
FR-TRUST-001	Trust shall create transfer cases: reference number, case type, quantity, annexure number	High
FR-TRUST-002	Transfer case reference numbers shall be unique (database-enforced)	High
FR-TRUST-003	Trust shall view all transfer cases ordered by last update date	High
FR-TRUST-004	Transfer cases shall support status: Pending, In Progress, Completed	High
FR-TRUST-005	Trust dashboard KPIs: Pending Annexure count, DI Slip Cases, Completed Transfers	Medium
FR-TRUST-006	Trust shall access a demat operations view showing the DI instruction queue	Medium

6.5 Dashboard & Analytics

Each user role shall have a personalised dashboard with role-specific KPIs and stock price visualisation.

Req. ID	Requirement	Priority
FR-DASH-001	Dashboard shall display role-specific KPI cards with live metric values	High
FR-DASH-002	Employee KPIs: My Grants count, Vested Options count, Exercise Requests count	High
FR-DASH-003	HR KPIs: Open Grants count, On Hold Cases count, Transfer Cases count	High
FR-DASH-004	Trust KPIs: Pending Annexure count, DI Slip Cases count, Completed Transfers count	High
FR-DASH-005	Dashboard shall render a stock price trend chart (line/sparkline)	Medium
FR-DASH-006	All dashboard data shall be fetched dynamically from the API on page load	High

6.6 Reports & Audit

All authenticated user roles shall have access to audit logs and operational reports.

Req. ID	Requirement	Priority
FR-RPT-001	System shall maintain an immutable audit log of all exercise requests with timestamps	High

FR-RPT-002	Audit log shall be paginated (configurable page size; default 10 records per page)	Medium
FR-RPT-003	System shall provide leave utilisation reports filterable by calendar year	Medium
FR-RPT-004	Leave utilisation report shall be paginated at employee-level granularity	Medium
FR-RPT-005	All authenticated users shall be able to access the Reports section	High

7. Non-Functional Requirements

7.1 Performance

Req. ID	Requirement	Target
NFR-PERF-001	API response time for authenticated requests (P95)	< 500 ms
NFR-PERF-002	Dashboard page load including data fetch	< 2 seconds
NFR-PERF-003	Concurrent users without performance degradation	>= 100 users
NFR-PERF-004	Paginated report query for up to 10,000 records	< 2 seconds

7.2 Security

Req. ID	Requirement	Target
NFR-SEC-001	All data in transit shall be encrypted	TLS 1.2+
NFR-SEC-002	JWT tokens shall expire to limit exposure window	8-hour expiry
NFR-SEC-003	Passwords shall be hashed with an adaptive algorithm	BCrypt
NFR-SEC-004	All API endpoints shall validate role-based authorisation	100% coverage
NFR-SEC-005	CORS policy shall restrict allowed origins to frontend	Configured

7.3 Availability & Reliability

Req. ID	Requirement	Target
NFR-AVAIL-001	System uptime during business hours	99.5% monthly
NFR-AVAIL-002	Planned maintenance window	Weekends / off-hours
NFR-AVAIL-003	Database backup frequency	Daily automated

7.4 Usability

Req. ID	Requirement	Target
NFR-USE-001	Responsive on modern desktop browsers	Chrome, Edge, Firefox
NFR-USE-002	Consistent, role-appropriate navigation via sidebar	All roles
NFR-USE-003	Error messages shall be descriptive and actionable	All forms

8. System Architecture

8.1 Three-Tier Architecture

Presentation Tier

React 18 SPA served via Vite (development) or a static build (production). Role-based routing and component rendering. JWT is stored in localStorage and injected as an Authorization: Bearer header on every API request.

Application Tier

ASP.NET Core 8.0 REST API. Controllers handle HTTP routing; Services encapsulate business logic; Entity Framework Core provides the data access layer. JWT middleware validates every protected request. CORS is configured to allow only the frontend origin.

Data Tier

MySQL 8.0 relational database. Schema managed via EF Core migrations. Connection pooling via the Pomelo MySQL provider. Database is auto-seeded on first run with test users and sample ESOP data.

8.2 API Endpoint Reference

Endpoint	Method	Authorisation	Description
/api/auth/login	POST	Public	Authenticate user — returns JWT, role, display name
/api/employee/profile	GET/PUT	Employee, HR	View or update employee profile
/api/employee/exercise	POST	Employee	Submit a stock option exercise request
/api/hr/grants	GET/ POST	HR	List all grants / create a new grant
/api/hr/separations	GET/ POST	HR	List or create employee separation cases
/api/trust/transfers	GET/ POST	Trust	List or create share transfer cases
/api/dashboard/{role}	GET	All Authenticated	Role-specific KPIs and stock trend data
/api/report/audit-logs	GET	All Authenticated	Paginated audit log of exercise requests
/api/report/leave-utilization	GET	All Authenticated	Employee leave utilisation by year

9. Data Requirements

9.1 Core Data Entities

Entity	Key Fields	Purpose
Users	Id, Email (unique), PasswordHash, Role, DisplayName, CreatedAt	Authentication and role assignment
EmployeeProfiles	EmployeeCode (unique), FullName, Department, DematAccount, NomineeName, PayrollBand	Employee master data
Grants	EmployeeCode, GrantDate, OptionCount, VestedCount, ExercisePrice, Status	ESOP grant records

ExerciseRequests	EmployeeCode, GrantId, RequestedOptions, PaymentMode, Status, RequestedAt	Option exercise tracking
SeparationCases	EmployeeCode, InitiationType, Status, EffectiveDate, Notes, CreatedAt	Employee separation management
TrustTransferCases	ReferenceNo (unique), CaseType, Status, Quantity, AnnexureNo, UpdatedAt	Share transfer operations

9.2 Data Retention Policy

- Exercise requests and audit logs: minimum 7 years (statutory requirement).
- Employee profiles: duration of employment plus 3 years post-separation.
- Grant records: full option exercise window plus applicable regulatory holding period.
- System/application logs: 1 year live, then archived for a further 3 years.

9.3 Development / UAT Seed Data

The application auto-seeds the following test data on first initialisation:

- 3 user accounts: emp@mahindra.com (Employee), hr@mahindra.com (HR), trust@mahindra.com (Trust)
- Default password for all seed accounts: Password@123
- 2 employee profiles: EMP001 - Aarav Iyer, EMP002 - Meera Nair
- 2 stock grants with different vesting states and exercise prices
- 1 separation case (EMP002) and 2 trust transfer cases (Pending + Completed)

10. Security Requirements

10.1 Authentication Security

Req. ID	Requirement	Implementation
SEC-001	Password complexity shall meet organisational standards	Min 8 chars, mixed case, digit, symbol
SEC-002	Passwords shall never be stored in plaintext	BCrypt with adaptive work factor
SEC-003	JWT tokens shall carry a defined expiry	8-hour expiry; re-login required after
SEC-004	JWT shall include issuer and audience claims for validation	Configured in appsettings.json
SEC-005	Failed login attempts shall be logged	Application-level audit logging

10.2 Authorisation Security

Req. ID	Requirement	Implementation
SEC-006	Every API endpoint shall enforce role-based authorisation	[Authorize(Roles="...")] on all controllers
SEC-007	Frontend shall enforce path-level role restrictions	Route guards in App.jsx
SEC-008	Users shall not access other employees' sensitive data	EmployeeCode-scoped queries throughout

SEC-009	CORS shall only permit requests from trusted frontend origins	Allowed-origins list in Program.cs
---------	---	------------------------------------

10.3 Data Security

Req. ID	Requirement	Implementation
SEC-010	All API traffic shall use HTTPS in production	TLS cert on reverse proxy / load balancer
SEC-011	Database credentials shall not be committed to source control	Environment variables / secrets manager
SEC-012	Sensitive fields (demat account) shall not appear in logs	Logging configuration / field masking
SEC-013	Data handling shall comply with India DPDP Act 2023	Data minimisation; consent tracking; retention policy

11. Integrations

11.1 Current State - v1.0 (Standalone)

MESOP v1.0 operates as a self-contained platform with no external system integrations. All data is managed within the application's MySQL database. Dashboard stock price trend data uses static mock values pending a live market-data feed.

11.2 Future Integration Roadmap

Integration	Priority	Description
Active Directory / LDAP SSO	High	Replace internal user DB with corporate IdP for seamless employee login
BSE / NSE Market Data Feed	High	Real-time stock price for dashboard trend charts and exercise price validation
Email Notification Service	Medium	Automated alerts: grant creation, exercise approval, status change notifications
SAP / Payroll Integration	Medium	Payroll deduction support for cashless option exercise payment mode
CDSL / NSDL Depository API	Low	Direct electronic demat instruction submission without manual intervention
Document Management System	Low	KYC and demat document upload, storage, and retrieval

12. Assumptions & Constraints

12.1 Assumptions

- Each employee has a unique Employee Code (e.g., EMP001) used consistently across all modules.
- Users are pre-provisioned by IT/HR admin; self-registration is not supported in v1.0.
- The MySQL database server is reachable from the backend application server at all times.
- Dashboard stock price trend is mock data in v1.0, pending a live market feed integration.
- Leave utilisation data in reports is mock data until HRMS integration is complete.
- All users access the system via modern web browsers (Chrome 100+, Firefox 100+, Edge 100+).
- The production environment provides TLS/HTTPS termination at the load balancer or reverse proxy.

- Demat account numbers are entered manually; no automated depository validation in v1.0.

12.2 Constraints

- The system must be deployable as Docker containers per Mahindra DevSecOps standards.
- The backend API must be compatible with the production domain: mesop-dev.m-devsecops.com.
- All personal and financial data must comply with the India DPDP Act 2023.
- JWT authentication must remain stateless; server-side session storage is not permitted.
- All database schema changes must be managed via Entity Framework Core migrations.
- The frontend must function as an SPA — server-side rendering is not required.

13. Risks & Mitigation

Risk	Likelihood	Impact	Mitigation Strategy
Unauthorised data access via misconfigured role policy	Low	High	Regular authorisation audits; role-boundary UAT test cases
Session hijacking via localStorage XSS	Medium	High	Short token expiry (8h); HTTPS; Content-Security-Policy headers
Database downtime causing application unavailability	Low	High	MySQL replication; daily automated backups; /health endpoint
Stale KPI data due to aggressive client-side caching	Medium	Medium	Fresh API fetch on each page load; avoid long-lived KPI cache headers
Duplicate exercise submission via rapid double-click	Medium	Medium	Disable submit button on first click; backend idempotency per grant+employee
DPDP non-compliance for employee PII	Low	High	Data minimisation design; automated retention purge; legal sign-off
Market-feed integration failure on future rollout	Medium	Low	Graceful degradation to mock data; circuit-breaker pattern; alerting
Brute-force account takeover	Low	High	Login rate limiting; account lockout; admin-only account management

14. Glossary

Term	Definition
ESOP	Employee Stock Option Plan — a benefit programme allowing employees to purchase company shares at a predetermined price.
MESOP	Mahindra Employee Stock Option Platform — the digital portal described in this document.
Grant	A formal allocation of a specified number of stock options to an eligible employee.
Vesting	The schedule by which an employee earns the irrevocable right to exercise granted options over time.

Exercise	The act of converting vested options into actual company shares at the agreed exercise price.
Exercise Price	The pre-agreed price at which an employee may purchase shares when exercising options.
Demat Account	A dematerialised account held with CDSL or NSDL to hold shares in electronic form.
DI Slip	Delivery Instruction Slip — a document authorising the transfer of shares out of a demat account.
Annexure	A supporting schedule or document attached to a share transfer instruction.
Trust	An employee benefit trust that holds Mahindra shares on behalf of the ESOP scheme participants.
JWT	JSON Web Token — a compact, URL-safe token standard used for stateless API authentication.
BCrypt	A password-hashing function deliberately designed to be slow and resistant to brute-force attacks.
DPDP Act	Digital Personal Data Protection Act, 2023 — India's principal data privacy legislation.
KPI	Key Performance Indicator — a measurable value used to evaluate progress against business objectives.
SPA	Single Page Application — a web app that loads a single HTML page and updates content dynamically.
ORM	Object-Relational Mapper — software that translates between application objects and database rows.
CORS	Cross-Origin Resource Sharing — an HTTP mechanism controlling which origins may access an API.
REST API	Representational State Transfer API — an architectural style for stateless web service communication.

Document Approval

This Business Requirements Document is pending sign-off from the following stakeholders:

Name	Role / Title	Signature	Date
	HR Technology Lead		
	CHRO / HR Leadership		
	IT / DevSecOps Lead		
	Finance Representative		